

Semana 4 — Objetivos de Aprendizado

Objetivos de Aprendizagem

Protocolos de Segurança de E-mail

Fundamentos de Segurança de E-mail

P: O que é autenticação de e-mail e por que ela é importante?

R: A autenticação de e-mail verifica que uma mensagem vem de quem afirma ser, prevenindo ataques de spoofing e phishing.

P: Quais são as principais ameaças contra as quais os protocolos de autenticação de e-mail protegem?

R: Spoofing de e-mail, phishing, falsificação de domínio, BEC (Business Email Compromise) e envio não autorizado em nome de um domínio.

P: Como SPF, DKIM e DMARC trabalham juntos para fornecer segurança abrangente de e-mail?

R: O SPF autoriza os servidores de envio, o DKIM verifica a integridade da mensagem por meio de assinaturas criptográficas, e o DMARC une ambos com verificações de alinhamento e políticas de aplicação.

P: Qual é a diferença entre spoofing de e-mail e falsificação de domínio?

R: O spoofing falsifica diretamente o endereço do remetente, enquanto a falsificação de domínio usa um domínio semelhante (ex.: paypa1.com em vez de paypal.com).

Sender Policy Framework (SPF)

P: O que é SPF e qual problema ele resolve?

R: O SPF é um protocolo baseado em DNS que especifica quais servidores de e-mail estão autorizados a enviar mensagens em nome de um domínio, impedindo que remetentes não autorizados façam spoofing desse domínio.

P: Como o SPF autoriza os servidores de envio de e-mail?

R: Publicando um registro TXT no DNS listando endereços IP, faixas e domínios incluídos que os receptores verificam em relação ao IP do servidor de conexão.

P: Qual é a sintaxe correta para um registro SPF?

R: `v=spf1 [mechanisms] [qualifier]all` — ex.: `v=spf1 ip4:192.0.2.0/24 include:_spf.google.com -all`.

P: Quais são os diferentes mecanismos do SPF (ip4, include, mx, a, all) e quando usar cada um?

R: ip4/ip6 para faixas de IP específicas, include para incorporar o SPF de outro domínio, mx para autorizar seus servidores MX, a para autorizar IPs do registro A do seu domínio, e all como padrão curinga.

P: Quais são os qualificadores do SPF (+pass, -fail, ~softfail, ?neutral) e o que significam?

R: + = pass (padrão), - = fail (rejeitar), ~ = softfail (marcar como suspeito mas aceitar), ? = neutral (sem declaração de política).

P: Qual é a ordem de avaliação do SPF e por que ela importa?

R: Os mecanismos são avaliados da esquerda para a direita; o primeiro mecanismo correspondente determina o resultado, portanto a ordem afeta quais regras têm prioridade.

P: Quais são os diferentes resultados do SPF (pass, fail, softfail, neutral, temperror, permerror)?

R: Pass = autorizado, fail = não autorizado, softfail = provavelmente não autorizado, neutral = sem declaração, temperror = erro transitório de DNS, permerror = erro permanente no registro (ex.: sintaxe inválida).

P: O que é o limite de 10 consultas DNS no SPF e por que ele existe?

R: A RFC 7208 limita a resolução dos mecanismos include, a, mx e redirect a 10 consultas no total para evitar ataques de amplificação de DNS e carga excessiva nos servidores receptores.

P: Por que o encaminhamento de e-mail quebra o SPF e como é possível mitigar isso?

R: O encaminhamento altera o IP de origem, falhando na verificação SPF do receptor; as mitigações incluem ARC (Authenticated Received Chain), SRS (Sender Rewriting Scheme) ou usar o DKIM, que sobrevive ao encaminhamento.

P: O que significa -all em um registro SPF e por que é importante?

R: Significa "reprovar todos os servidores não explicitamente autorizados", garantindo que qualquer remetente não listado seja marcado como não autorizado — a postura de aplicação mais rigorosa.

P: Como você testa e valida um registro SPF?

R: Use dig TXT domain.com, ferramentas online como MXToolbox ou dmarcian, ou envie e-mails de teste e inspecione o cabeçalho Received-SPF.

DomainKeys Identified Mail (DKIM)

P: O que é DKIM e como ele difere do SPF?

R: O DKIM anexa uma assinatura criptográfica às mensagens verificada por meio de uma chave pública no DNS, comprovando a integridade do conteúdo e a autorização do remetente — diferentemente do SPF, que valida apenas o IP do servidor de envio.

P: Como o DKIM usa assinaturas criptográficas para verificar a autenticidade do e-mail?

R: O servidor de envio assina cabeçalhos e o corpo selecionados com uma chave privada; o receptor recupera a chave pública do DNS e verifica a assinatura.

P: O que é um seletor DKIM e por que os seletores são usados?

R: Um seletor é uma string no cabeçalho DKIM que identifica qual chave específica buscar no DNS, permitindo múltiplas chaves simultâneas e rotação de chaves.

P: Quais são os componentes de um cabeçalho de assinatura DKIM?

R: Os campos principais incluem v (versão), a (algoritmo), b (valor da assinatura), bh (hash do corpo), d (domínio), h (cabeçalhos assinados), s (seletor) e c (canonicalização).

P: Como funciona o processo de assinatura DKIM passo a passo?

R: 1) Canonicalizar cabeçalhos/corpo → 2) Gerar hash do corpo → 3) Assinar cabeçalhos selecionados e hash do corpo com a chave privada → 4) Anexar o cabeçalho DKIM-Signature → 5) Enviar.

P: Como funciona o processo de verificação DKIM passo a passo?

R: 1) Extrair seletor e domínio do DKIM-Signature → 2) Consultar [selector]._domainkey.[domain] no DNS pela chave pública → 3) Canonicalizar → 4) Verificar a assinatura com a chave pública → 5) Comparar o hash do corpo.

P: Quais são os métodos de canonicalização (simple/simple, relaxed/relaxed) e quando usar cada um?

R: Simple preserva cabeçalhos/corpo exatamente; relaxed tolera alterações de espaço em branco/capitalização — relaxed é preferido para cabeçalhos e corpo, pois servidores de e-mail frequentemente modificam o conteúdo em trânsito.

P: Qual é o formato de um registro DNS DKIM?

R: Um registro TXT em [selector]._domainkey.[domain] contendo v=DKIM1; k=rsa; p=[chave-pública-em-base64].

P: Como você gera chaves DKIM e qual tamanho de chave deve usar?

R: Use OpenSSL (openssl genrsa -out private.pem 2048) — mínimo RSA 2048 bits; 4096 bits recomendado para uso de longo prazo; Ed25519 também é suportado atualmente.

P: Por que o DKIM é compatível com encaminhamento enquanto o SPF não é?

R: Porque a assinatura DKIM viaja com a mensagem e é verificada contra o DNS (independentemente do IP de envio), enquanto o SPF falha quando o IP de conexão muda durante o encaminhamento.

P: O que é rotação de chaves DKIM e como realizá-la?

R: Publicar um novo par seletor/chave junto ao antigo, permitindo que mensagens assinadas já em trânsito ainda sejam verificadas pela chave antiga antes de removê-la — geralmente feito a cada 6 a 12 meses.

P: Como você testa e valida assinaturas DKIM?

R: Envie um e-mail de teste e inspecione o cabeçalho Authentication-Results, use ferramentas como DKIM Validator, ou verifique manualmente com dig TXT selector._domainkey.domain.com.

Domain-based Message Authentication, Reporting & Conformance (DMARC)

P: O que é DMARC e como ele se baseia no SPF e no DKIM?

R: O DMARC usa os resultados do SPF e do DKIM somados a verificações de alinhamento entre os endereços do envelope/domínio/from para determinar uma ação de política (none/quarantine/reject) e fornece relatórios.

P: Quais são as tags obrigatórias e opcionais do DMARC?

R: Obrigatórias: v (versão) e p (política); Opcionais: rua (relatórios agregados), ruf (relatórios forenses), sp (política de subdomínio), pct (percentual), ri (intervalo de relatório), adkim/aspf (modo de alinhamento).

P: Quais são os três níveis de política do DMARC (none, quarantine, reject) e o que cada um faz?

R: none = somente monitoramento, sem aplicação; quarantine = enviar mensagens reprovadas para spam; reject = descartar completamente as mensagens reprovadas.

P: O que é alinhamento DMARC e por que é importante?

R: O alinhamento garante que o domínio no cabeçalho From corresponda ao domínio validado pelo SPF (remetente do envelope) ou pelo DKIM (tag d=), fechando brechas em que um SPF/DKIM aprovado poderia pertencer a um domínio diferente.

P: Qual é a diferença entre os modos de alinhamento estrito e relaxado?

R: O estrito exige correspondência exata de domínio; o relaxado permite correspondência de domínio organizacional (ex.: mail.example.com se alinha com example.com).

P: Como o DMARC avalia a autenticação de e-mail (verificações de SPF e DKIM)?

R: Verifica se o SPF é aprovado e o domínio do envelope se alinha com o cabeçalho From, OU se o DKIM é aprovado e o domínio DKIM se alinha com o cabeçalho From — qualquer um é suficiente.

P: Quais são as condições para um resultado de aprovação no DMARC?

R: Pelo menos um dos pares SPF + alinhamento ou DKIM + alinhamento deve ser aprovado — ou seja, autenticado e alinhado com o domínio do From.

P: O que é a tag pct e como é usada para aplicação gradual de políticas?

R: pct=X aplica a política DMARC a X% das mensagens reprovadas, permitindo implantação incremental (ex.: pct=10 coloca em quarentena apenas 10% das falhas).

P: O que é a tag sp e como ela afeta as políticas de subdomínio?

R: sp define uma política DMARC separada para subdomínios; se omitida, os subdomínios herdam a política p — útil para rejeitar spoofing de subdomínios enquanto monitora o domínio raiz.

P: O que são relatórios agregados DMARC (RUA) e quais informações eles contêm?

R: Relatórios XML enviados periodicamente ao endereço RUA contendo IP de envio, resultados de SPF/DKIM/DMARC, contagens e resultados de política — usados para monitorar a autenticação em todos os remetentes.

P: O que são relatórios forenses DMARC (RUF) e quando são enviados?

R: Relatórios de falha individuais enviados por mensagem quando o DMARC falha, contendo os cabeçalhos originais da mensagem e às vezes o corpo — úteis para análise forense, mas levantam preocupações de privacidade.

P: Como você analisa relatórios DMARC?

R: Use ferramentas como dmarcian, a ferramenta DMARC do Postmark, parsedmarc (Python) ou plataformas comerciais que processam relatórios XML/RUA e apresentam dashboards.

P: Qual é a estratégia recomendada de implantação do DMARC?

R: Comece com p=none com monitoramento via rua → analise os relatórios → avance para p=quarantine com pct baixo → aumente gradualmente → mude para p=reject.

Integração de Protocolos

P: Como SPF, DKIM e DMARC trabalham juntos no fluxo de autenticação de e-mail?

R: O receptor verifica o SPF (IP autorizado?), o DKIM (assinatura válida?), depois o DMARC (algum deles se alinha com o cabeçalho From?) → aplica a política DMARC adequadamente.

P: O que acontece quando o SPF é aprovado mas o DKIM falha (e vice-versa)?

R: O DMARC ainda é aprovado se o que passou se alinhar com o cabeçalho From — apenas uma aprovação com alinhamento é necessária.

P: O que acontece quando tanto SPF quanto DKIM falham?

R: O DMARC falha, e o receptor aplica a política DMARC do domínio (none/quarantine/reject).

P: Como o DMARC usa os resultados de SPF e DKIM para tomar decisões de política?

R: O DMARC combina os resultados de aprovação/reprovação de cada um com verificações de alinhamento; se nenhum se alinhar e for aprovado, aplica a política publicada.

P: Contra quais ameaças cada protocolo protege?

R: O SPF previne spoofing de IP não autorizado, o DKIM previne adulteração de conteúdo e verifica a identidade do remetente, o DMARC previne spoofing de domínio e fornece aplicação + visibilidade.

P: Quais são as limitações de cada protocolo?

R: O SPF falha no encaminhamento e tem limite de 10 consultas; o DKIM pode falhar se intermediários modificarem o conteúdo; o DMARC protege apenas o domínio do cabeçalho From e requer pelo menos uma aprovação com alinhamento.

Implementação e Configuração

P: Como você implementa o SPF para um domínio?

R: Publique um registro TXT na raiz do domínio: v=spf1 [fontes-autorizadas] -all.

P: Como você implementa o DKIM para um domínio?

R: Gere um par de chaves, configure seu servidor de e-mail para assinar mensagens enviadas e publique a chave pública em [selector]._domainkey.[domain] como um registro TXT.

P: Como você implementa o DMARC para um domínio?

R: Publique um registro TXT em _dmarc.[domain]: v=DMARC1; p=none; rua=mailto:dmarc@domain.com.

P: Qual é a ordem correta para implementar protocolos de autenticação de e-mail?

R: SPF primeiro → DKIM segundo → DMARC por último (começando em p=none com relatórios).

P: Como você configura políticas de subdomínio?

R: Use a tag sp no registro DMARC, ou publique um registro DMARC separado em _dmarc.subdomain.domain.com.

P: Como você lida com serviços de e-mail de terceiros em registros SPF?

R: Use diretivas include: apontando para o registro SPF do provedor (ex.: include:_spf.google.com), observando o limite de 10 consultas.

P: Como você soluciona falhas de autenticação?

R: Inspecione os cabeçalhos Authentication-Results e Received-SPF, valide registros DNS com dig/ferramentas online, verifique o alinhamento e analise os relatórios DMARC.

P: Onde são publicados os registros de SPF, DKIM e DMARC no DNS?

R: SPF na raiz do domínio, DKIM em [selector]._domainkey.[domain], DMARC em _dmarc.[domain].

P: Qual tipo de registro DNS é usado para registros de autenticação de e-mail?

R: Registros TXT para os três (SPF, DKIM e DMARC).

P: Como você consulta registros DNS usando dig, nslookup ou ferramentas online?

R: dig TXT domain.com (SPF), dig TXT selector._domainkey.domain.com (DKIM), dig TXT _dmarc.domain.com (DMARC); ou use MXToolbox/dmarcian.

P: Qual é o formato de cada tipo de registro DNS?

R: SPF: v=spf1 ... -all; DKIM: v=DKIM1; k=rsa; p=[chave]; DMARC: v=DMARC1; p=none; rua=....

P: Como funcionam as consultas DNS para includes do SPF?

R: Cada include: aciona uma consulta TXT recursiva no domínio referenciado, contando para o limite de 10 consultas.

P: Como funcionam as consultas DNS para chaves públicas DKIM?

R: O verificador constrói a consulta [selector]._domainkey.[d=domain] e recupera o registro TXT contendo a chave pública.

Boas Práticas e Erros Comuns

P: Quais são as boas práticas para configuração de registros SPF?

R: Mantenha abaixo do limite de 10 consultas, termine com -all, evite +all, use ip4/ip6 sempre que possível e use serviços de SPF flattening se houver muitos includes.

P: Quais são as boas práticas para gerenciamento de chaves DKIM?

R: Use RSA 2048+ ou Ed25519, rotacione as chaves a cada 6 a 12 meses, use seletores duplos durante a rotação e armazene as chaves privadas com segurança.

P: Quais são as boas práticas para implantação de políticas DMARC?

R: Comece em p=none com relatórios rua, analise os relatórios minuciosamente, avance incrementalmente para quarantine e depois reject, e defina sp=reject para subdomínios cedo.

P: Quais são os erros comuns na implementação de autenticação de e-mail?

R: Usar +all ou ~all no SPF, pular o DKIM, implantar o DMARC em p=reject imediatamente, exceder o limite de 10 consultas e negligenciar remetentes terceiros.

P: Como você evita o limite de 10 consultas DNS do SPF?

R: Use endereços IP diretamente em vez de include:, consolide includes com ferramentas de SPF flattening, ou use um serviço de SPF delegado.

P: Por que você nunca deve usar +all em um registro SPF?

R: Isso autoriza explicitamente todos os IPs da internet a enviar e-mail a partir do seu domínio, anulando completamente o propósito do SPF.

P: Por que você deve começar com p=none no DMARC antes de aplicar políticas?

R: Para coletar relatórios e identificar todos os remetentes legítimos antes da aplicação, evitando falsos positivos que bloqueiam e-mails válidos.

P: Com que frequência as chaves DKIM devem ser rotacionadas?

R: A cada 6 a 12 meses é recomendado, ou imediatamente se uma chave privada for comprometida.

Solução de Problemas

P: Como você diagnostica falhas de autenticação SPF?

R: Verifique o cabeçalho Received-SPF, valide o IP de envio em relação ao registro SPF, procure problemas na cadeia de includes e confirme que o registro não excede 10 consultas.

P: Como você diagnostica falhas de assinatura DKIM?

R: Verifique se a chave pública está publicada corretamente no DNS, procure modificações de corpo/cabeçalho em trânsito (incompatibilidade de canonicalização), confirme que o seletor existe e certifique-se de que o tamanho da chave é suportado.

P: Como você diagnostica problemas de política DMARC?

R: Analise os relatórios agregados DMARC, verifique o alinhamento entre os domínios SPF/DKIM e o cabeçalho From, e confirme que o registro DMARC está publicado em _dmarc.[domain].

P: Quais ferramentas você pode usar para testar a autenticação de e-mail?

R: MXToolbox, dmarcian, mail-tester.com, DKIM Validator, dig/nslookup e Parsedmarc para análise de relatórios.

P: Como você lê e interpreta cabeçalhos de e-mail?

R: Visualize o código-fonte completo da mensagem e rastreie de baixo (mais antigo) para cima (mais recente), observando os cabeçalhos Authentication-Results, Received-SPF, DKIM-Signature e Received.

P: Como você analisa relatórios agregados DMARC?

R: Processe relatórios XML via ferramentas como parsedmarc ou dashboards comerciais, depois revise quais IPs/remetentes aprovam ou reprovam na autenticação e no alinhamento.

P: Quais são as causas comuns de falhas de autenticação?

R: Remetentes terceiros não listados no SPF, cadeias de include quebradas, corpos de mensagem modificados quebrando o DKIM, domínios desalinhados, registros DNS ausentes/expirados e cenários de encaminhamento.

Protocolos de Rede: Auditoria e Segurança

Princípios Fundamentais de Segurança e Diferenciação de Protocolos

P: Quais são os três objetivos centrais de segurança que os protocolos seguros visam alcançar?

R: Confidencialidade, integridade e disponibilidade (a tríade CIA).

P: Qual é a principal diferença entre protocolos de camada de aplicação e protocolos de camada de rede?

R: A camada de aplicação opera na camada 7 do modelo OSI (serviços voltados ao usuário), enquanto a camada de rede opera na camada 3 (roteamento e endereçamento).

P: Explique o conceito de números de porta e sua importância na comunicação de rede.

R: Os números de porta identificam aplicações ou serviços específicos em execução em um host, permitindo a multiplexação das comunicações.

Protocolos Seguros de Web e Acesso Remoto

P: Qual é a diferença entre SSL e TLS, e qual é realmente usado hoje?

R: O TLS é o sucessor moderno; o SSL é obsoleto e inseguro.

P: Como funciona o handshake TLS ao acessar um site seguro?

R: Cliente e servidor negociam algoritmos de criptografia, autenticam-se via certificados e estabelecem chaves de sessão antes da transferência de dados.

P: Qual problema o SSH resolveu que protocolos mais antigos como o Telnet não conseguiam lidar?

R: O SSH fornece acesso remoto a shell criptografado, enquanto o Telnet transmite todos os dados (incluindo credenciais) em texto claro.

P: Como funciona a autenticação SSH com chaves públicas?

R: O cliente prova sua identidade usando uma chave privada sem transmiti-la, enquanto o servidor verifica contra uma chave pública armazenada.

P: Diferencie protocolos seguros como HTTPS, SFTP e seus equivalentes inseguros HTTP, FTP.

R: As versões seguras criptografam os dados em trânsito; as versões inseguras transmitem texto claro vulnerável à interceptação.

P: Explique por que o HTTPS é obrigatório para a confiança do usuário, proteção de dados e recursos modernos da web.

R: Ele previne ataques man-in-the-middle, protege dados sensíveis e é exigido pelos navegadores para o tratamento de conteúdo misto.

Protocolos de Camada de Rede e VPN

P: Qual é a diferença entre o Modo de Transporte e o Modo de Túnel no IPSec, e qual é usado em VPNs?

R: O modo de transporte criptografa apenas o payload; o modo de túnel criptografa o pacote inteiro — o modo de túnel é usado em VPNs.

P: Qual é a diferença entre os protocolos AH (Authentication Header) e ESP (Encapsulating Security Payload) no IPSec?

R: O AH fornece apenas autenticação; o ESP fornece tanto criptografia quanto autenticação.

P: Por que o PPTP nunca deve ser usado em tarefas sensíveis à segurança?

R: Ele possui fraquezas criptográficas conhecidas e vulnerabilidades, incluindo a quebra do MSCHAPv2.

P: O que torna o protocolo moderno WireGuard mais rápido e eficiente do que protocolos VPN tradicionais como o OpenVPN?

R: Base de código mais simples, criptografia moderna (ChaCha20, Curve25519) e design sem estado reduzem a sobrecarga.

Auditoria de Protocolos Comuns e Avaliação de Riscos

P: Explique o propósito do protocolo Network File System (NFS) e como configurações incorretas podem levar ao compartilhamento exposto.

R: O NFS permite o compartilhamento de arquivos em redes; controles de acesso inadequados expõem diretórios sensíveis a usuários não autorizados.

P: Descreva como os comandos SMTP VRFY e EXPN podem ser explorados para enumeração de usuários em um servidor de e-mail.

R: Esses comandos revelam endereços de e-mail/nomes de usuário válidos, possibilitando ataques de phishing direcionados.

P: Explique o propósito do SNMP e os riscos de segurança associados a dados não criptografados e strings de comunidade padrão.

R: O SNMP monitora dispositivos, mas as configurações padrão permitem que atacantes leiam/escrevam configurações de dispositivos com esforço mínimo.

Hardening de Sistemas e Gerenciamento de Vulnerabilidades

P: Explique a importância de manter protocolos de rede e configurações de servidores atualizados e com patches aplicados.

R: Sistemas sem patches contêm vulnerabilidades conhecidas exploráveis por atacantes com exploits publicados.

P: Explique a necessidade de configurar regras básicas de firewall (como usar iptables) para controlar o acesso à rede.

R: Firewalls filtram tráfego não autorizado e limitam a superfície de ataque bloqueando portas desnecessárias.

P: Identifique fraquezas comuns de configuração SSH que exigem hardening (permitir login como root, autenticação por senha).

R: Desabilitar o login root, a autenticação por senha e aplicar autenticação baseada em chave reduz riscos de força bruta e escalonamento de privilégios.

Reconhecimento Passivo

P: O que podemos descobrir sobre um servidor?